NAVY POČÍTAČOVÁ BEZPEČNOST

Cv2. Příprava prostředí pro penetrační testování

Nasazení zranitelných aplikací (DVWA a Juice Shop) a úvodní průzkum

Cíl cvičení: Vyzkoušet si nasazení tradiční zranitelné aplikace (DVWA) a porovnat ji s moderní verzí zranitelné aplikace Juice Shop. Student by měl provést základní průzkum z pohledu běžného uživatele i útočníka.

Krok 1: Historické okénko – Nasazení a seznámení s DVWA

Nejprve si ukážeme, jak vypadala tradiční výuka na starších technologiích (PHP/MySQL). Použijeme k tomu aplikaci DVWA (Damn Vulnerable Web App).

1. Nejjednodušší cesta je využít Docker. Spusťte v terminálu tento příkaz:

   ```
   docker run --rm -p 8080:80 vulnerables/web-dvwa
   ```
2. Připojte se v prohlížeči na adresu http://localhost:8080.
3. Přihlaste se výchozími údaji: uživatel **admin**, heslo **password**.
4. Při prvním spuštění musíte sjet úplně dolů a kliknout na tlačítko **Create / Reset Database**, čímž se aplikace inicializuje. Následně se znovu přihlaste.
5. **Průzkum:** Prozkoumejte levé menu. Všimněte si, že zranitelnosti (SQLi, XSS, atd.) jsou zde seřazené jako v katalogu. Aplikace nevypadá jako reálný web, ale jako seznam úkolů. Dle pokynů cvičícího dokončete nastavení aplikace a následně se s ní krátce seznamte. Zajímavá je pak záložka security, kde je možné nastavit úroveň zabezpečení webové stránky.

Krok 2: Nasazení OWASP Juice Shop

Nyní nasadíme moderní aplikaci napsanou v Node.js a Angularu, která reprezentuje současný stav internetu.

1. Spusťte v novém okně terminálu tento příkaz:

   ```
   docker run --rm -p 3000:3000 bkimminich/juice-shop
   ```

2. Připojte se v prohlížeči na adresu http://localhost:3000
   Všimněte si toho rozdílu – aplikace vypadá jako naprosto běžný, reálný e-shop a nikde tu není žádné "hackerské menu".

Krok 3: Pasivní průzkum

Než začnete cokoliv testovat, tak musíte pochopit, jak aplikace funguje. Útočník sbírá data o cíli a připravuje taktiku útoku.

- **Chovejte se jako zákazník:** Proklikejte si aplikaci. Zkuste vyhledat produkt, podívejte se na recenze, klikněte na stránku "About Us", zjistěte, kde je přihlašovací formulář.
- **Co by vás mělo zajímat:** Jak vypadají URL adresy (např. /#/search?q=apple)? Jak aplikace reaguje, když zadáte nesmysl do vyhledávání?

Krok 4: Práce s vývojářskými nástroji

Protože je Juice Shop moderní Single Page Application (SPA) napsaná v Angularu, obrovské množství logiky (a potenciálních chyb) se nachází přímo u vás v prohlížeči.

1. Otevřete Vývojářské nástroje.
2. Překlikněte na záložku **Console (Konzole)**. Vidíte tam nějaké varování nebo zajímavé zprávy od vývojářů?
3. Překlikněte na záložku **Network (Síť)** a obnovte stránku. Sledujte, jaké soubory si prohlížeč od serveru stahuje (zejména se zaměřte na .json).

Krok 5: Hlavní úkol – Najděte Scoreboard

Vaším prvním skutečným úkolem je najít skrytou stránku výsledkové tabule (Scoreboard). Na této stránce uvidíte seznam všech dostupných zranitelností a váš postup v reálném čase.

Problém: Odkaz na tuto stránku v hlavním menu nenajdete. Vývojáři aplikovali anti-pattern zvaný *Security through obscurity* (Bezpečnost skrze utajení) – myslí si, že když odkaz skryjí, nikdo stránku nenajde.

Jak na to? Zde jsou postupné nápovědy (použijte je, až když nebudete vědět jak dál):

- **Nápověda 1 (Hádání URL):** Zkusili jste prostě uhodnout cestu v adresním řádku?
- **Nápověda 2 (Roboti):** Co dělá vyhledávač (jako Google), když indexuje nový web?
- **Nápověda 3 (Zdrojový kód):** V DevTools (F12) běžte do záložky **Sources (Zdroje)**, najděte hlavní JavaScriptový soubor (např. main.js). Je to sice zkomprimovaný a nepřehledný kód, ale pomocí zkratky Ctrl+F v něm můžete vyhledávat. Zkuste najít slova jako "score" nebo "board".

Úspěšné dokončení

Naleznete korektní adresu scoreboardu a uvidíte první zeleně odškrtnutý úkol. Od této chvíle zde můžete sledovat svůj postup.

Krok 6: Bonusový úkol – Automatizovaný průzkum s Gobusterem

Vyzkoušejte si automatizované skenování, což je standardní technika, jakou útočníci prohlubují své znalosti o systému. Nástroj gobuster slouží k odhalení skrytých složek a souborů na serveru.
V moderních aplikacích typu SPA (jako je Juice Shop) gobuster nenajde samotný Scoreboard (protože cesty s mřížkou # se neodesílají na server), ale může odhalit skryté systémové složky a API rozhraní.

Základní použití nástroje Gobuster: gobuster dir -u https://example.com -w common.txt

Godbuster: https://github.com/OJ/gobuster
SecLists: https://github.com/danielmiessler/SecLists
Základní slovník klíčových názvů:
https://raw.githubusercontent.com/danielmiessler/SecLists/master/Discovery/Web-Content/common.txt